

Cybersecurity Management Plan

Grounded in: BD Alaris™ Infusion System (cleared 510(k), 2023)

Basis: FDA 2025 premarket cybersecurity guidance structure; device facts public.

Manufacturer	Becton, Dickinson and Company (BD)
Device	BD Alaris™ Infusion System (Point-of-Care Unit + pump/syringe/PCA modules)
Pathway / status	510(k) — cleared July 21, 2023 (updated software with enhanced cybersecurity + EMR interoperability)
Cyber device?	Yes — Wi-Fi connectivity + EMR interoperability; multi-module connected platform
Regulatory basis	FD&C Act §524B; FDA Premarket Cybersecurity Guidance (2025); AAMI SW96; ISO 14971; IEC 81001-5-1

1. Scope & system context

A connected acute-care infusion platform: the Point-of-Care Unit (PCU) coordinates infusion modules and exchanges programming with hospital EMRs over the facility network. Related systems include the server-side device manager, the EMR interoperability interface, and the maintenance/update channel.

2. Governance & SPDF

Product Security Owner / PSIRT accountable for the total product lifecycle. Security activities are executed inside a Secure Product Development Framework integrated with the QMS (design controls).

3. Security risk management

Security risk file maintained per AAMI SW96 and integrated with the ISO 14971 safety risk file. Threats scored on exploitability and patient-harm; residual risks formally accepted by Security and Quality.

4. Architecture views

- Global system view — PCU, modules, EMR interface, device manager, update channel.
- Multi-patient harm view — a unit/server compromise must not enable fleet-wide dosing changes.
- Updateability/patchability view — signed software distribution to the installed base.
- Security use-case views — clinician auth, EMR auto-programming, remote service.

5. Software Bill of Materials (SBOM)

Machine- and human-readable SBOM (CycloneDX) covering OS, networking, and crypto components, with support/EOL and a known-vulnerability list; maintained through postmarket.

6. Security controls (8 categories)

Category	Representative control
Authentication	Authenticated access to PCU configuration and service interfaces
Authorization	Role-based access; least privilege for service accounts
Cryptography	Encrypted EMR/data-in-transit; protected credentials at rest
Code & data integrity	Signed software/firmware; integrity checks on update
Confidentiality	Protection of PHI exchanged with the EMR
Event detection / logging	Security-relevant audit logging available to the facility
Resiliency / recovery	Safe-state behavior; recovery from network loss
Firmware / software updates	Controlled, signed distribution to the installed base

7. Verification & validation (testing)

- Static analysis (SAST) and software-composition analysis (SCA) in CI.
- Dynamic analysis (DAST) of network/EMR interfaces.
- Independent penetration test with findings closed or risk-accepted.
- Coverage rationale traced to the threat model.

8. Postmarket & coordinated disclosure

Continuous SBOM-to-CVE and CISA KEV monitoring; published CVD policy; severity-based patch timelines; field correction/removal assessed under 21 CFR 806 and MDR under 803.

9. Labeling

Security labeling (MDS2) and a hardening/secure-configuration guide describing supported network configurations and operational controls for the deploying facility.

Sources (public)

- FDA / BD — “BD Receives FDA 510(k) Clearance for Updated BD Alaris Infusion System” (Jul 21, 2023).
- FDA — Cybersecurity in Medical Devices: QMS Considerations and Content of Premarket Submissions (final, Jun 27, 2025).
- AAMI SW96; ISO 14971; IEC 81001-5-1.